

REPORT DI AUDIT TECNICO- PROGETTO OMEGA

1. Sintesi dell'Infrastruttura L'infrastruttura analizzata comprende un server web basato su architettura Linux e un database PostgreSQL. L'audit si è focalizzato sulla verifica delle configurazioni di rete e della gestione degli accessi.

2. Vulnerabilità Rilevate (Findings)

- **Identificativo: FINDING-01 – Gestione Insicura delle Credenziali** Durante l'ispezione della cartella /opt/app/config, è stato rinvenuto un file denominato db_config.py. All'interno del file, le credenziali dell'utente amministratore (DB_USER="admin" e DB_PASS="P@ssw0rd123!") sono scritte in chiaro (plaintext). Questa pratica espone il sistema ad accessi non autorizzati in caso di compromissione del server web.
- **Identificativo: FINDING-02 – Trasmissione Dati non Criptata** L'analisi del traffico di rete tramite l'applicativo ha rivelato che il modulo di autenticazione invia i token di sessione e le password tramite il protocollo HTTP (porta 80) anziché HTTPS. La mancanza di crittografia (TLS) permette a un potenziale attaccante posizionato nella stessa rete di intercettare le sessioni (sniffing).
- **Identificativo: FINDING-03 – Mancato Patching di Servizi Critici** Il server applicativo utilizza una versione obsoleta di Apache Struts (vulnerabile a CVE-2017-5638). Non è stato riscontrato alcun piano di aggiornamento per le librerie Java, esponendo il perimetro a vulnerabilità di Remote Code Execution (RCE).
- **Identificativo: FINDING-04 – Credenziali di Default** L'interfaccia di gestione del router interno è accessibile tramite le credenziali predefinite di fabbrica (admin/admin). Questo rappresenta un punto di ingresso facilitato per tecniche di movimento laterale all'interno della rete.

3. Valutazione del Rischio La combinazione di credenziali hardcoded e comunicazione non criptata indica un elevato rischio di esfiltrazione dati. La presenza di servizi non patchati aumenta la probabilità di un'intrusione esterna con privilegi elevati.